MAXIMUS

THE AI BRAIN THAT THINKS LIKE AN APPLICATION SECURITY TESTER

Security Assessment Report

Test_Application

OVERALL RISK · CRITICAL

CLIENT	test_app
CATEGORY	Website
TARGET	http://testasp.vulnweb.com/
STATUS	active
ISSUED	2026-09-30 11:04 UTC

CONFIDENTIAL

This document is intended solely for the named recipient. Generated by MAXIMUS — The AI brain that thinks like an application security tester.

Table of Contents

01 Executive Summary 3

02 Findings (16) 5

02.1 CRITICAL SQL Injection — showforum.asp (id parameter) 5

02.2 CRITICAL SQL Injection — Authentication Bypass (Login.asp) 5

02.3 CRITICAL SQL Injection — showthread.asp (id parameter) 6

02.4 CRITICAL SQL Injection — Search.asp (tfSearch parameter) 6

02.5 HIGH Plaintext HTTP — No TLS/SSL Encryption 6

02.6 HIGH Path Traversal — Templatize.asp (item parameter) 7

02.7 HIGH Plaintext Password Storage in Database 7

02.8 MEDIUM IIS FrontPage Metadata Exposure (_vti_cnf) 7

02.9 MEDIUM HTTP TRACE Method Enabled 8

02.10 MEDIUM CSRF — No Anti-CSRF Tokens on State-Changing Forms 8

02.11 MEDIUM Server/Technology Version Disclosure 8

02.12 MEDIUM Verbose Error Messages (500 Stack Traces) 9

02.13 MEDIUM Clickjacking — Missing X-Frame-Options / frame-ancestors CSP 9

02.14 MEDIUM Stored XSS via Forum Posts 10

02.15 LOW Session Cookie Missing HttpOnly and Secure Flags 10

02.16 INFO Missing Security Headers 11

03 Reconnaissance Data (17) 12

04 Credentials Discovered & Used (1) 13

01 Executive Summary

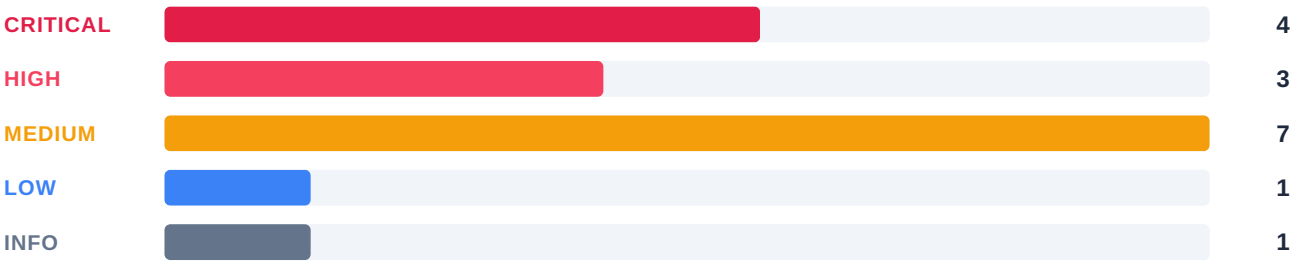
OVERALL RISK LEVEL

CRITICAL

16 findings identified during the engagement, of which **7** require immediate remediation (critical or high severity). See section 02 for full technical details.

16	0	17	46
FINDINGS	OBSERVATIONS	RECON ITEMS	COMMANDS RUN

Findings by Severity



Key Findings

#	SEVERITY	TITLE	TARGET	CVSS
F-1	CRITICAL	SQL Injection — showforum.asp (id parameter)	http://testasp.vulnweb.com/showforum.asp?id=	9.3
F-2	CRITICAL	SQL Injection — Authentication Bypass (Login.asp)	http://testasp.vulnweb.com/Login.asp	9.3
F-3	CRITICAL	SQL Injection — showthread.asp (id parameter)	http://testasp.vulnweb.com/showthread.asp?id=	9.3
F-4	CRITICAL	SQL Injection — Search.asp (tfSearch parameter)	http://testasp.vulnweb.com/Search.asp?tfSearch=	9.3
F-5	HIGH	Plaintext HTTP — No TLS/SSL Encryption	http://testasp.vulnweb.com/	8.2

Showing top 5 of 16 findings — see section 02 for the complete list.

Scope

Web application security assessment including frontend, backend API, authentication mechanisms, session management, and business logic.

Target Domains

http://testasp.vulnweb.com/

Objectives

Identify vulnerabilities in the web application following OWASP Testing Guide methodology.

Limitations

No denial-of-service testing. No social engineering. Testing limited to provided scope.

02 Findings

CRITICAL SQL Injection — showforum.asp (id parameter) #F-1

TARGET	http://testasp.vulnweb.com/showforum.asp?id=		
STATUS	confirmed	CVSS 4.0	9.3
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N		

TECHNICAL ANALYSIS

The `id` parameter in showforum.asp is vulnerable to boolean-based blind, stacked queries, and time-based blind SQL injection on MSSQL backend. sqlmap confirmed 6 databases (acuforum, acuservice, master, model, msdb, tempdb) with 4 tables in acuforum (forums, posts, threads, users). Passwords stored in plaintext in users table (uname, upass columns).

PROOF OF CONCEPT

GET /showforum.asp?id=0 OR 1=1-- → 200 OK, dumps all threads across all forums. Single quote (id=0') → 500 Internal Server Error. sqlmap payloads: boolean-based (id=1 AND 2491=2491), stacked queries (id=1;WAITFOR DELAY '0:0:5'--), time-based blind (id=1 WAITFOR DELAY '0:0:5').

CRITICAL SQL Injection — Authentication Bypass (Login.asp) #F-2

TARGET	http://testasp.vulnweb.com/Login.asp		
STATUS	confirmed	CVSS 4.0	9.3
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N		

TECHNICAL ANALYSIS

The login form's tfUName parameter is vulnerable to SQL injection allowing complete authentication bypass. No input validation or parameterized queries in place.

PROOF OF CONCEPT

POST /Login.asp with tfUName=' OR '1'='1'--&tfUPass=anything → 302 redirect to Default.asp with authenticated session. Username displayed as "'OR'1'='1'--" in logout link confirming auth bypass.

CRITICAL SQL Injection — showthread.asp (id parameter) #F-3

TARGET	http://testasp.vulnweb.com/showthread.asp?id=
STATUS	confirmed
CVSS 4.0	9.3
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

The id parameter in showthread.asp triggers a 500 error on single quote injection, confirming unparameterized SQL query on MSSQL backend.

PROOF OF CONCEPT

GET /showthread.asp?id=1' → 500 Internal Server Error

CRITICAL SQL Injection — Search.asp (tfSearch parameter) #F-4

TARGET	http://testasp.vulnweb.com/Search.asp?tfSearch=
STATUS	confirmed
CVSS 4.0	9.3
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

The tfSearch parameter in Search.asp triggers a 500 error on single quote injection via GET, confirming unparameterized SQL query.

PROOF OF CONCEPT

GET /Search.asp?tfSearch=test' → 500 Internal Server Error

HIGH Plaintext HTTP — No TLS/SSL Encryption #F-5

TARGET	http://testasp.vulnweb.com/
STATUS	confirmed
CVSS 4.0	8.2
VECTOR	CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

The entire application runs over HTTP (port 80) with no HTTPS/TLS support. All traffic including login credentials, session cookies, and user data is transmitted in cleartext, vulnerable to network sniffing and MITM attacks.

PROOF OF CONCEPT

SSL analysis failed — no certificate present. Nmap port 443 — closed. Site only serves on port 80/HTTP.

HIGH Path Traversal — Templatize.asp (item parameter) #F-6

TARGET	http://testasp.vulnweb.com/Templatize.asp?item=
STATUS	confirmed
CVSS 4.0	8.7
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

The item parameter in Templatize.asp allows directory traversal using backslash sequences to read arbitrary files from the Windows server filesystem. No path sanitization is applied.

PROOF OF CONCEPT

GET /Templatize.asp?item=.....\windows\win.ini → 200 OK with win.ini content: ''; for 16-bit app support [fonts] [extensions] [mci extensions] [files] [Mail] MAPI=1"

HIGH Plaintext Password Storage in Database #F-7

TARGET	http://testasp.vulnweb.com/ (acuforum.users table)
STATUS	confirmed
CVSS 4.0	8.7
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

The users table has a `upass` column (nvarchar) storing passwords. Combined with the confirmed SQL injection, passwords can be extracted directly. Login with test/test works, and sqlmap confirmed the table structure — passwords are stored without hashing or encryption.

PROOF OF CONCEPT

```
sqlmap: acuforum.users columns = uname (nvarchar), upass (nvarchar), email, realname, avatar.
Login with provided creds test:test succeeds, confirming plaintext comparison. Auth bypass via
SQLi also succeeds without password check.
```

MEDIUM IIS FrontPage Metadata Exposure (_vti_cnf) #F-8

TARGET	http://testasp.vulnweb.com/_vti_cnf/
STATUS	confirmed
CVSS 4.0	6.9
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

FrontPage _vti_cnf directory is publicly accessible, leaking internal file structure, backlink information, and FrontPage extension version (4.0.2.8912). Reveals all ASP page names and relationships.

PROOF OF CONCEPT

GET /_vti_cnf/ → 200 OK with vti_extenderversion:SR|4.0.2.8912, vti_backlinkinfo listing login.asp, register.asp, search.asp, default.asp, showthread.asp, showforum.asp, templatize.asp

MEDIUM

HTTP TRACE Method Enabled #F-9

TARGET	http://testasp.vulnweb.com/
STATUS	confirmed
CVSS 4.0	6.9
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

The server responds to OPTIONS request with Allow: OPTIONS, TRACE, GET, HEAD, POST. TRACE method is enabled which can be exploited for Cross-Site Tracing (XST) attacks to steal credentials or session cookies via XSS+TRACE combination.

PROOF OF CONCEPT

OPTIONS / → Allow: OPTIONS, TRACE, GET, HEAD, POST; Public: OPTIONS, TRACE, GET, HEAD, POST

MEDIUM

CSRF — No Anti-CSRF Tokens on State-Changing Forms #F-10

TARGET	http://testasp.vulnweb.com/Login.asp, /Register.asp
STATUS	confirmed
CVSS 4.0	5.1
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

Login and Registration forms use POST method but contain no CSRF tokens, no referrer validation, and no SameSite cookie attribute. An attacker can craft a page that auto-submits a registration or login form on behalf of a victim.

PROOF OF CONCEPT

Register form: <form action="" method="post"> with fields tfUName, tfRName, tfEmail, tfUPass — no hidden CSRF token field. Login form: same pattern, no anti-CSRF protection.

MEDIUM

Server/Technology Version Disclosure #F-11

TARGET	http://testasp.vulnweb.com/
STATUS	confirmed
CVSS 4.0	6.9
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

Server exposes exact IIS version (Microsoft-IIS/8.5) in Server header and ASP.NET in X-Powered-By header. FrontPage extensions version 4.0.2.8912 is exposed via _vti_cnf. This aids attackers in identifying known vulnerabilities for specific versions.

PROOF OF CONCEPT

Server: Microsoft-IIS/8.5, X-Powered-By: ASP.NET, vti_extenderversion:SR|4.0.2.8912

MEDIUM

Verbose Error Messages (500 Stack Traces) #F-12

TARGET	http://testasp.vulnweb.com/
STATUS	confirmed
CVSS 4.0	6.9
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

The application returns HTTP 500 errors on malformed input instead of handling errors gracefully. While custom error pages are shown (not full stack traces), the 500 status code itself confirms unhandled exceptions and aids in vulnerability discovery (e.g., confirming SQL injection points).

PROOF OF CONCEPT

GET /showforum.asp?id=0' → 500 Internal Server Error. GET /Search.asp?tfSearch=test' → 500 Internal Server Error. GET /showthread.asp?id=1' → 500 Internal Server Error.

MEDIUM

Clickjacking — Missing X-Frame-Options / frame-ancestors CSP #F-13

TARGET	http://testasp.vulnweb.com/
STATUS	confirmed
CVSS 4.0	5.1
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

No X-Frame-Options header and no Content-Security-Policy frame-ancestors directive. Application can be embedded in an iframe on a malicious site enabling clickjacking attacks on authenticated actions (login, registration, posting).

PROOF OF CONCEPT

Response headers contain no X-Frame-Options and no CSP frame-ancestors directive.

MEDIUM

Stored XSS via Forum Posts #F-14

TARGET	http://testasp.vulnweb.com/showthread.asp		
STATUS	confirmed	CVSS 4.0	4.8
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N		

TECHNICAL ANALYSIS

Forum post content is rendered directly into HTML without sanitization or encoding. The showthread.asp page renders user-posted content inside div.posttext without output encoding. The site itself warns it's deliberately vulnerable to such attacks, and real-world malicious posts with encoded payloads are visible in thread listings.

PROOF OF CONCEPT

showthread.asp renders post body in: {user_content} — no HTML entity encoding. Thread titles from attacker posts contain Cyrillic/encoded characters confirming no input validation. The site warning explicitly states: "deliberately vulnerable to SQL Injections, directory traversal, and other web-based attacks".

LOW

Session Cookie Missing HttpOnly and Secure Flags #F-15

TARGET	http://testasp.vulnweb.com/		
STATUS	confirmed	CVSS 4.0	2.1
VECTOR	CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N		

TECHNICAL ANALYSIS

Session cookie ASPSESSIONIDCACRQDSA is set without HttpOnly, Secure, or SameSite flags. This makes it vulnerable to theft via XSS attacks and MITM interception since the site runs on plain HTTP.

PROOF OF CONCEPT

Set-Cookie: ASPSESSIONIDCACRQDSA=DMCCAKOBBCMCKNMGBFJBPOLG; path=/ — No HttpOnly, no Secure, no SameSite attribute.

INFO

Missing Security Headers #F-16

TARGET	http://testasp.vulnweb.com/
STATUS	confirmed
CVSS 4.0	0.0
VECTOR	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

TECHNICAL ANALYSIS

Response headers are missing critical security headers: Content-Security-Policy, X-Content-Type-Options, X-Frame-Options, Strict-Transport-Security, Referrer-Policy, Permissions-Policy. Additionally, X-Powered-By: ASP.NET header leaks technology stack information.

PROOF OF CONCEPT

GET / response headers: Server: Microsoft-IIS/8.5, X-Powered-By: ASP.NET. No CSP, no X-Frame-Options, no X-Content-Type-Options, no HSTS.

03 Reconnaissance Data

TECHNOLOGY 2 items

Microsoft-IIS/8.5	type: web_server
ASP.NET (Classic ASP)	type: framework

PORT 1 item

80/tcp - HTTP	state: open · service: http

SERVICE 1 item

No HTTPS/SSL configured	note: Site runs on plain HTTP only

ENDPOINT 13 items

/login.asp	—
/register.asp	—
/search.asp	—
/showthread.asp	—
/db.asp	—
/default.asp	—
/logout.asp	—
/_vti_cnf	—
/aspnet_client	—
/avatars	—
/images	—
/jscripts	—
/templates	—

04 Credentials Discovered & Used

SECRETS VISIBLE — this copy contains plaintext credentials. Passwords, tokens and cookies are embedded in clear text below. Treat this PDF as highly sensitive: encrypt at rest, restrict distribution, and rotate every credential before sharing externally.

User 1 BASIC_AUTH

USERNAME	test
PASSWORD	test
PLACEHOLDER	`{{BASIC_AUTH_USER_1}}`
DISCOVERED	manual

NOTICE — AI-ASSISTED ASSESSMENT

This report was generated with the assistance of MAXIMUS, an AI-driven security assessment platform. AI can make mistakes: findings, severities, recommendations, and reasoning may contain errors, hallucinations, or omissions.

Please double-check every finding against the raw evidence (commands, payloads, output) before relying on this report for remediation, disclosure, or regulatory purposes. A qualified human reviewer should validate the report before distribution.